Security Requirements Specification

Online Bookstore

Security requirements for the online book buying and selling platform

1. Introduction

This document lists the security requirements for the Online Bookstore system. It adds detail to the security, legal and interoperability requirements already in the Software Requirements Specification (NFR-6, NFR-10 and NFR-11) and applies them to the buyer, seller and admin features described in FR-1 to FR-15.

Each requirement has an ID in the form SEC-n. The last column shows the functional requirement (FR), non-functional requirement (NFR) or use case (UC) it comes from, so that it can be traced back to the SRS and the Use Case Flow document.

2. Assets to Protect

The requirements in section 3 are aimed at protecting the following.

Asset	What needs protecting
User accounts	Email, phone number, password hashes, session tokens and reset OTPs of buyers, sellers and admins.
Personal data	Names, shipping addresses and contact details held for orders and notifications.
Payment information	Card and payment details handled by the payment gateway, and the transaction reference the system stores.
Orders and invoices	Order contents, status history, totals, discounts and generated invoices.
Listings and reviews	Book listings, stock levels, prices and buyer reviews, which must not be changed by the wrong person.
Admin functions	Moderation tools that can approve, suspend or remove listings and accounts.

3. Security Requirements

Requirements are grouped by area. Where a value such as a time limit is given, it is a proposed value and is also listed in section 4 so that the team can confirm it.

3.1 Authentication and Account Security

Req ID	Security Requirement Description	Related To
SEC-1	Passwords shall be at least 8 characters long and contain at least one letter and one digit. Weaker passwords shall be rejected at registration and when a password is changed or reset.	FR-1, FR-14, UC1
SEC-2	Passwords shall be stored only as salted hashes made with a slow, adaptive algorithm (for example bcrypt or Argon2). Plain-text or reversibly encrypted passwords shall never be stored.	FR-1, NFR-6
SEC-3	After 3 consecutive failed login attempts the system shall show a lockout warning and lock the account temporarily (see section 4 for the lockout time).	FR-1, UC1

Req ID	Security Requirement Description	Related To
SEC-4	Login and password reset messages shall be generic and shall not reveal whether an email address or phone number belongs to an account.	FR-14, UC2
SEC-5	Password reset links and OTPs shall be single use and shall expire after a short fixed time. An expired or already used code shall be rejected.	FR-14, UC2
SEC-6	The number of OTP or reset requests per account shall be limited, to stop the reset feature being used to flood a user with messages.	FR-14, UC2

3.2 Session Management

Req ID	Security Requirement Description	Related To
SEC-7	A random, unguessable session token shall be issued at login. It shall only be sent over TLS and, if stored in a cookie, the cookie shall be marked Secure and HttpOnly.	FR-1, UC1
SEC-8	A session shall expire after a period of inactivity, and logging out shall invalidate the token on the server.	FR-1
SEC-9	All active sessions of a user shall be ended when that user's password is changed or reset.	FR-14, UC2

3.3 Access Control and Authorisation

Req ID	Security Requirement Description	Related To
SEC-10	Access shall be role based (Buyer, Seller, Admin). Permissions shall be checked on the server for every request; hiding a button or page in the interface does not count as access control.	FR-1, FR-7, FR-8, FR-12
SEC-11	Buyers shall only be able to see their own orders, order status, cart and wishlist. A request for anyone else's data shall return an authorisation error.	FR-4, FR-9, FR-15, UC12
SEC-12	Sellers shall only be able to add, edit or remove their own listings and manage orders that contain their own listings.	FR-7, FR-8, UC14, UC15
SEC-13	Approving, suspending or removing listings and accounts shall be limited to Admin accounts. Each action shall record who did it, what it was applied to, the reason and the time.	FR-12, UC16
SEC-14	Admin accounts shall need a second authentication step (for example an OTP sent through the Email / Notification Service) in addition to the password.	FR-1, FR-12
SEC-15	A review shall only be accepted from a buyer who has a delivered order containing that book.	FR-10, UC13

3.4 Data Protection

Req ID	Security Requirement Description	Related To
SEC-16	All traffic between the browser and the server shall use TLS 1.2 or higher. Plain HTTP requests shall be redirected to HTTPS.	NFR-6
SEC-17	Personal data such as phone numbers and shipping addresses shall be protected at rest by encryption, and passwords as described in SEC-2.	NFR-6, NFR-10

Req ID	Security Requirement Description	Related To
SEC-18	Passwords, OTPs, session tokens and payment details shall never be written to logs, URLs or error messages.	NFR-6
SEC-19	Error messages shown to users shall be generic. Technical details such as stack traces and database errors shall only go to protected server logs.	NFR-6
SEC-20	Database backups shall be encrypted, and access to them shall be limited to authorised staff.	NFR-2, NFR-6

3.5 Payment Security

Req ID	Security Requirement Description	Related To
SEC-21	The system shall not store card numbers, CVV codes or other card details. These go directly to the payment gateway, and the system keeps only the transaction reference.	FR-5, UC9
SEC-22	Item prices, shipping, tax, discounts and the order total shall be calculated on the server. Amounts sent from the browser shall not be trusted.	FR-5, FR-11, UC8
SEC-23	An order shall only be created after a successful result from the payment gateway has been verified on the server. A timeout or unknown result shall not create an order.	FR-5, UC9
SEC-24	Discount codes shall be validated on the server, shall respect per-buyer usage limits, and attempts to guess codes shall be rate limited.	FR-11, UC7

3.6 Input Handling and Application Security

Req ID	Security Requirement Description	Related To
SEC-25	All user input (forms, search terms, filters and URL parameters) shall be validated on the server for type, length and format.	FR-1, FR-2, FR-7
SEC-26	Database queries shall use parameterised statements so that user input cannot change the query (SQL injection).	NFR-8
SEC-27	User-written content such as reviews and listing descriptions shall be encoded when displayed, so that scripts cannot be injected into pages (XSS).	FR-7, FR-10
SEC-28	Requests that change data, such as placing an order, editing a listing or updating an order status, shall be protected against cross-site request forgery (CSRF).	FR-5, FR-7, FR-8
SEC-29	Reviews flagged by the content filter shall be held for moderation and not published until an Admin approves them.	FR-10, FR-12, UC13
SEC-30	Login, registration, password reset and search shall be rate limited to slow down automated abuse.	FR-1, FR-2, NFR-2

3.7 Logging and Monitoring

Req ID	Security Requirement Description	Related To
SEC-31	The system shall log security events: successful and failed logins, lockouts, password resets, admin actions, authorisation failures and failed payments. Each entry shall have a time and, where known, the user ID.	FR-12, NFR-6

Req ID	Security Requirement Description	Related To
SEC-32	Logs shall be protected from changes, readable only by authorised staff, and kept for a fixed retention period (see section 4).	NFR-6

3.8 Privacy and Compliance

Req ID	Security Requirement Description	Related To
SEC-33	The system shall collect only the data needed to run the store, namely account, delivery and order details.	NFR-10
SEC-34	The registration page shall link to a privacy notice that explains what data is collected and why.	FR-1, NFR-10
SEC-35	Users shall be able to ask for their personal data to be corrected or deleted, except for order and invoice records that must be kept for legal or accounting reasons.	NFR-10

3.9 Third-party Integrations and Development Practice

Req ID	Security Requirement Description	Related To
SEC-36	Payment, shipping and notification integrations shall use authenticated, documented APIs over TLS.	NFR-11
SEC-37	API keys, database passwords and other secrets shall be kept in environment configuration or a secrets store, never in the source code or the repository.	NFR-8, NFR-11
SEC-38	Third-party libraries shall be checked for known vulnerabilities and updated regularly.	NFR-7
SEC-39	Code review before merge shall include a security check, and unit tests shall cover the security rules above, such as lockout, input validation and access control.	NFR-7, NFR-9

4. Values to Confirm

The values below are proposals made while writing this document. The SRS and Use Case Flow do not fix them, so the team should confirm or change them.

Item	Proposed value	Used in
Account lockout time after 3 failed logins	15 minutes	SEC-3
Password reset OTP / link validity	10 minutes	SEC-5
OTP / reset requests per account	5 per hour	SEC-6
Session inactivity timeout	30 minutes	SEC-8
Security log retention	90 days	SEC-32